

System Security

Attacks:

- *Unauthorized logging to a machine*
- *Virus, worm, or Trojan horse*

These attacks can be introduced into the system through the network or diskette.

Intruders

- ✓ *Generally referred to as a hacker or cracker*
- ✓ *Intruder can be a disgruntled employee who wishes to do damage, or a criminal who seeks to exploit computer assets for financial gain(e.g., obtaining credit card numbers or performing illegal money transfers)*
- ✓ *There are three classes of Intruders:*
 1. *Masquerader*
 2. *Misfeasor*
 3. *Clandestine user*

Three Classes Of Intruders

Masquerader: *An individual who is not authorized to use the computer and who penetrates a system's access controls to exploit a legitimate user's account*

Misfeasor: *A legitimate user who accesses data, programs, or resources for which such access is not authorized, or who is authorized for such access but misuses his or her privileges*

Clandestine user: *An individual who seizes supervisory control of the system and uses this control to evade auditing and access controls or to suppress audit collection*

Intrusion Techniques

- ✓ *Objective of the intruder* → *Gain access to a system and acquire information that should have been protected*
- ✓ *This information is in the form of a user password*
- ✓ *System must maintain a file that associates a password with each authorized user. If such a file is stored with no protection, then it is an easy matter to gain access to it and learn passwords.*

Protection

- ✓ *The front line of defense against intruders is the login and password system*
- ✓ *User has to provide not only a name or identifier(ID) but also a password*
- ✓ *The ID provides security in the following ways:*
 - *The ID determines whether the user is authorized to gain access to a system*
 - *The ID determines the privileges accorded to the user*
 - *The ID is used in discretionary access control*

PROTECTION OF THE PASSWORD FILE

✓ Can be protected in one of two ways:

One-way encryption

✓ The system stores only an encrypted form of the user's password. When the user enters a password, the system encrypts that password and compares it with the stored value

Access control

✓ Access to the password file is limited to one or a very few accounts

Techniques for learning passwords

- 1. Try default passwords. Many administrators do not bother to change these defaults*
- 2. Exhaustively try all short passwords(one to three chars length)*
- 3. Try words in the system's on-line dictionary or a list of likely passwords*
- 4. Try user's phone numbers, Social Security numbers*
- 5. Collect information about users, such as their full names, the names of family members*
- 6. Use a Trojan horse to bypass restrictions on access*

The Vulnerability of Passwords

✓ *In UNIX systems, passwords are never stored in the clear*

Fig 9.1 shows the UNIX password scheme

✓ *Each user selects a password (8 printable characters in length). This is converted into a 56-bit value(using 7-bit ASCII) that serves as the key input to an encryption routine(Crypt(3)). It is based on DES*

✓ *The DES algorithm is modified using a 12-bit salt value*

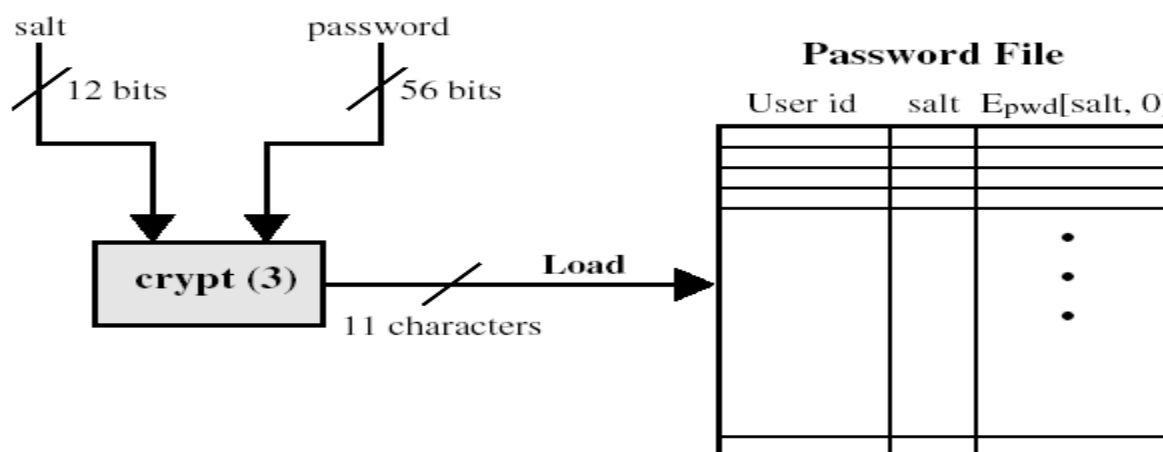
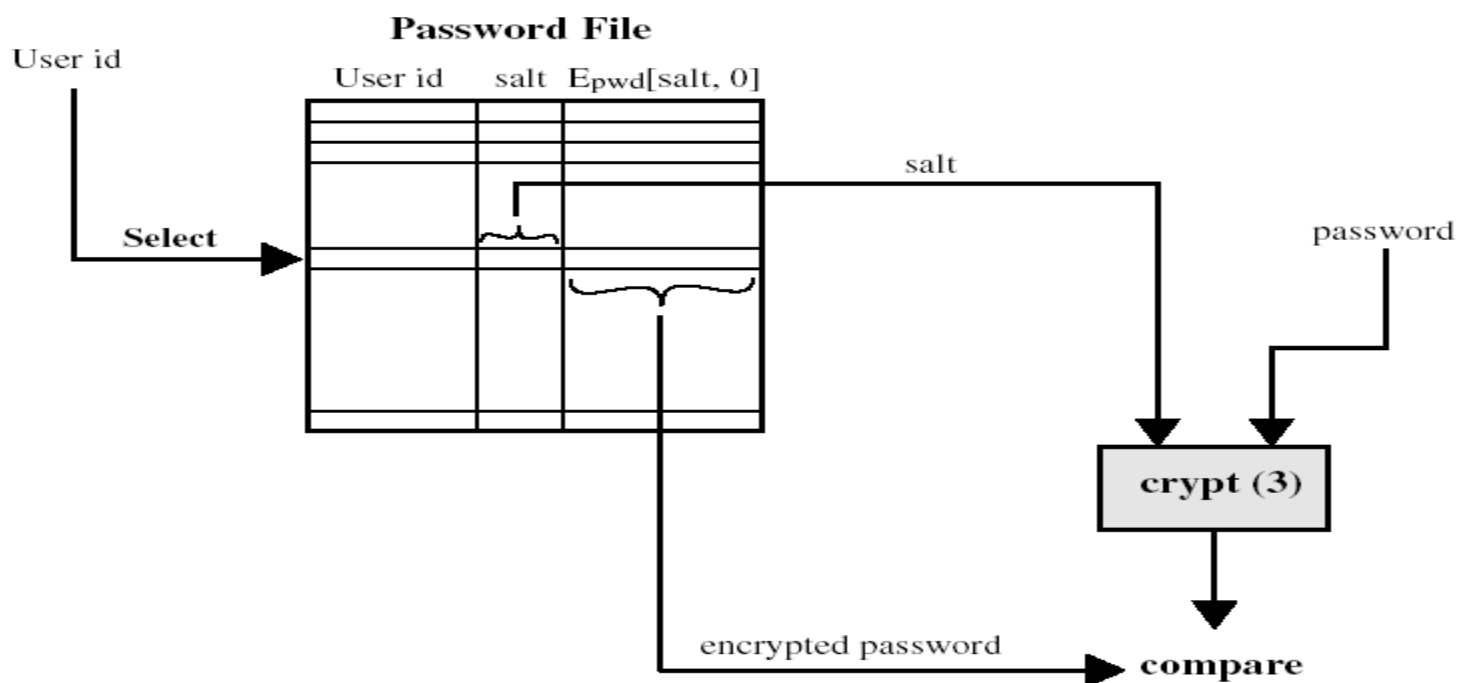


Figure 9.1 UNIX Password Scheme



- ✓ *Salt value is related to the time at which the password is assigned to the user*
- ✓ *The modified DES algorithm is exercised with a data input consisting of a 64-bit block of zeros*
- ✓ *The output of the algorithm then serves as input for a second encryption*
- ✓ *This process is repeated for a total of 25 encryptions. The resulting 64-bit output is then translated into an 11-character sequence*
- ✓ *The ciphertext password is then stored, together with a plaintext copy of the salt, in the password file for the corresponding user ID*

✓ *The salt serves three purposes:*

1. *It prevents duplicate passwords from being visible in the password file*
2. *It effectively increases the length of the password without requiring the user to remember two additional characters*
3. *It prevents the use of a hardware implementation of DES*

✓ *The encryption routine is designed to discourage guessing attacks*

Password Selection Strategies: *Four basic techniques are in use:*

1.User education	Provide guidelines to the users for selecting passwords
2.Computer-generated passwords	Random number generator produces a random stream of characters used to construct the passwords
3.Reactive password checking	In which the system periodically runs its own password cracker to find guessable passwords.The system cancels any passwords that are guessed and notifies the user
4.Proactive password checking	User is allowed to select his or her own password. At the time of selection, the system checks to see if the password is allowable and, if not, rejects it.

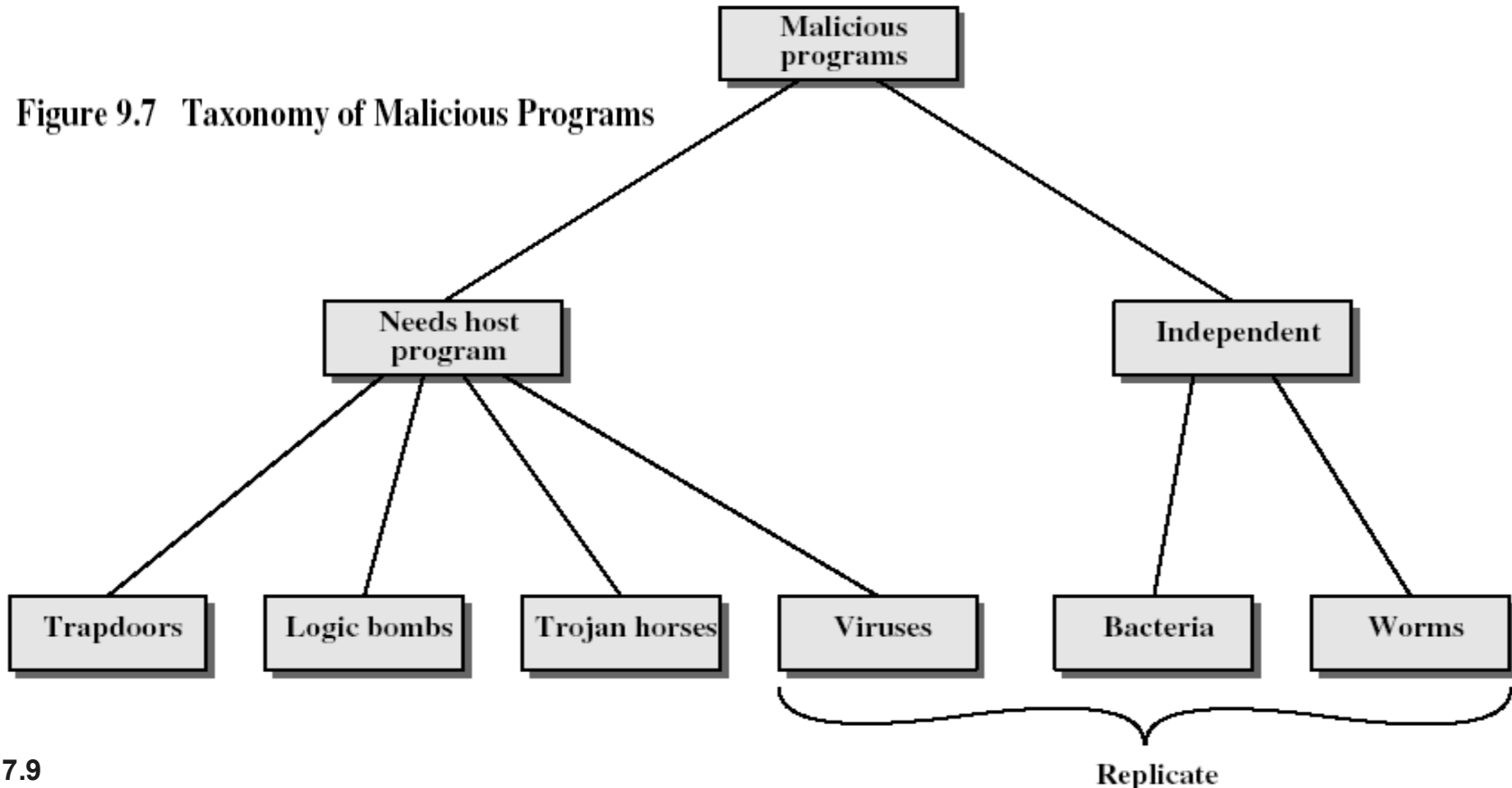
Viruses and Related Threats

✓ *Threats to computer systems are presented by programs (Application programs and utility programs such as editors and compilers) that exploit vulnerabilities in computing systems*

Malicious Programs

✓ *Fig 9.7 provides an overall taxonomy of software threats, or malicious programs*

✓ Needs host program: These are fragments (Virus) of programs that are to be activated when the host program is invoked to perform a specific function



✓ Independent:

These are independent programs (worm, bacteria) that, when executed, may produce one or more copies of itself to be activated later on the same system or some other system

Trap doors:

✓ *Trap door is a secret entry point into a program that allows someone that is aware of the trapdoor to gain access without going through the usual security procedures*

✓ *Trap door becomes threats when they are used by unscrupulous programmers to gain unauthorized access*

✓ *It is difficult to implement operating system controls for trap doors*

Logic Bomb:

✓ *The logic bomb is code embedded in some legitimate program that is set to **explode when certain conditions are met***

Trojan Horses:

✓ *Trojan horse is a useful program or command procedure containing hidden code that, when invoked, performs some unwanted or harmful function*

✓ *Trojan horse programs can be used to **accomplish functions indirectly** that an unauthorized user could not accomplish directly*

✓ *For example, to gain access to the files of another user on a shared system, a user create a Trojan horse program that, when executed, changed the invoking user's file permissions so that the files are readable by any user*

✓ *Another common motivation for the Trojan horse is **data destruction**. The program appears to be performing a useful function(e.g., a calculator program), but it may also be quietly deleting the user's files*

Viruses:

- ✓ *Virus is a program that can "infect" other programs by modifying them; the modification includes a copy of the virus program, which can then go on to infect other programs*
- ✓ *Lodged in a host computer, the typical virus takes temporary control of the computer's disk operating system. Then, whenever the infected computer comes into contact with an uninfected piece of software, a fresh copy of the virus passes into the new program. Thus the infection can be spread from computer to computer over a network*
- ✓ *A computer virus carries code for making perfect copies of itself*

Worms

✓ *Network worm programs use network connections to spread from system to system*

✓ *Once active within a system, a network worm can behave as a computer virus or bacteria or it could implant Trojan horse programs or perform any number of destructive actions*

✓ *To replicate itself, a network worm uses some sort of network vehicle which includes the following:*

-*Electronic mail facility: A worm mails a copy of itself to others*

-*Remote execution capability: A worm executes a copy of itself on another system*

-*Remote login capability: A worm logs onto a remote system as a user and then uses commands to copy itself from one system to the other*

Bacteria

- ✓ *Bacteria are programs that **do not explicitly damage any files***
- ✓ *The purpose is to **replicate themselves***
- ✓ *They create files, which are copies of the original files, again these create same copies of files, and so on*
- ✓ ***Bacteria reproduce exponentially, eventually taking up all the processor capacity, memory, or disk space, denying users access to those resources***

The Nature of Viruses

- ✓ *A virus can do anything that other programs do. The only difference is that it attaches itself to another program and executes secretly when the host program is run*
- ✓ *Once a virus is executing, it can perform any function, such as erasing files and programs*

Virus Structure and the four stages

Virus Structure

- ✓ *A virus can be preponed or postponed to an executable program, or it can be embedded in some other fashion*
- ✓ *The key to its operation is that the infected program, when invoked, will first execute the virus code and then execute the original code of the program*

During its life time, a typical virus goes through the following four stages:

1. *-Dormant phase: The virus is idle*
2. *-Propagation phase: The virus places an identical copy of itself into other programs*
3. *-Triggering phase: The virus is activated to perform the function for which it was intended*
4. *-Execution phase: The function is performed*

✓ *The key lines in this virus are numbered, and Fig 9.10 illustrates the operation*

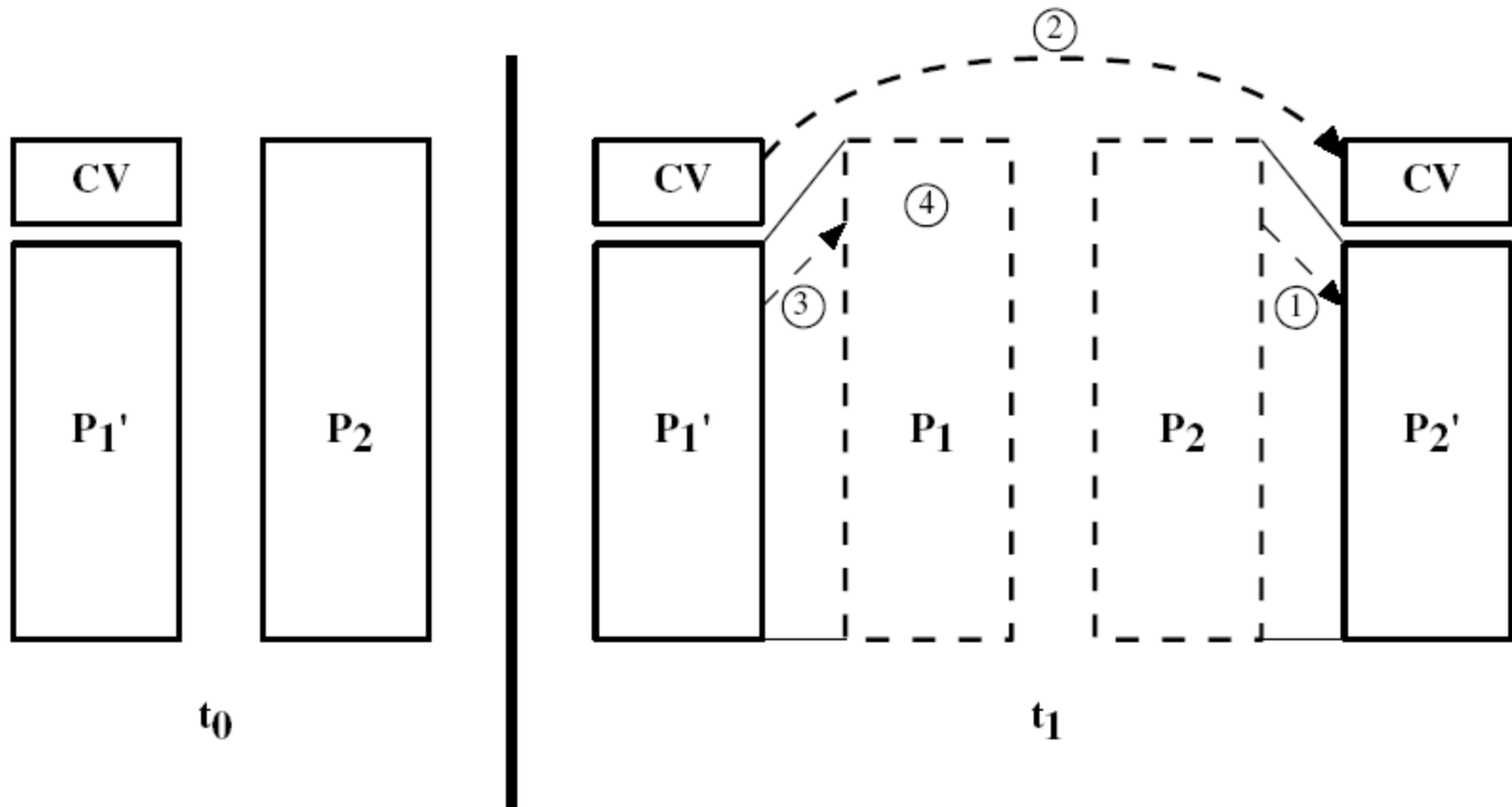


Figure 9.10 A Compression Virus

✓ *Assume that program P1 is infected with the virus CV. When this program is invoked, control passes to its virus, which perform the following steps:*

1. For each uninfected file P2 that is found, the virus first compresses that file to produce P2', which is shorter than the original program by the size of the virus
2. A copy of the virus is prepended to the compressed program
3. The compressed version of the original infected program, P1', is uncompressed
4. The uncompressed original program is executed

In this example, the virus does nothing other than propagate. As in the previous example, the virus may include a logic bomb

Types of Viruses

1. Parasitic virus: It attaches itself to executable files and replicates, when the infected program is executed, by finding other executable files to infect
2. Memory-resident virus: Lodges in main memory as part of a resident system program. From that point on, the virus infects every program that executes
3. Boot sector virus: Infects a master boot record or boot record and spreads when a system is booted from the disk containing the virus
4. Stealth virus: A form of virus explicitly designed to hide itself from detection by antivirus software
5. Polymorphic virus: A virus that mutates with every infection, making detection by the “signature” of the virus impossible

Antivirus Approaches

- ✓ *The ideal solution to the threat of viruses is prevention*
- ✓ *The next best approach is to be able to do the following:*
 1. *-Detection: Once the infection has occurred, determine that it has occurred and locate the virus*
 2. *-Identification: Once detection has been achieved, identify the specific virus that has infected a program*
 3. *-Removal: Once the specific virus has been identified, remove all traces of the virus from the infected program and restore it to its original state*
- ✓ *If detection succeeds but either identification or removal is not possible, then the alternative is to discard the infected program and reload a clean backup version*